M365-11 · SharePoint & OneDrive Permission Management

How access to organization content is granted, inherited, reviewed and removed — and the four habits that break it.

Field	Value
Document ID	M365-11
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	A. Microsoft 365
Operating tier	Tier 2 — Advanced Technical Services, which already owns permissions. Architecture questions go to Tier 3.
Review cycle	Annually.
Depends on	M365-15. Permission decisions have no anchor without a classification scheme; where M365-15 is not yet adopted, treat everything holding records about identifiable people as CONFIDENTIAL.

1. Purpose

This document says how somebody gets access to a SharePoint site or a OneDrive, how that access is structured so it can be understood later, and how it goes away. It is short by design: permissions go wrong through a handful of specific habits, and naming them is more useful than a comprehensive treatment nobody reads.

2. The model — groups, not people

> **Access is granted to a group. Always.**
>
> A person is added to a group; the group has access to the site. Nobody is ever granted access as an individual, even for “just this once”.
>
> The reason is legibility. A site permissioned to twelve named individuals cannot be reasoned about — you cannot tell why any of them are there, whether they still should be, or what to do when one leaves. A site permissioned to two groups tells you the answer at a glance.
>
> It also makes the leaver procedure work. Removing somebody from three groups is reliable; hunting for individual grants across an unknown number of sites is not, and that is the step ACC-01 §7.2 depends on.

Group	Holds
Site Owners	The named owner and deputy. Can change permissions. Two or three people, never more.
Site Members	People who work in the site. Can add and edit content.
Site Visitors	People who need to read it. Use this generously — read access is cheap and it is what stops people asking for edit access they do not need.
ROLE-groups	Role-based access from ACC-02 — for example ROLE-HR-TempWorker. Added to Members or Visitors as appropriate, so a role change is one membership edit.

3. The four habits that break permissions

Habit	Why it happens	What to do instead
Granting to an individual	Faster in the moment, and the request named a person.	Add them to the group. If no group fits, that is a signal the site needs a new group, not an exception.
Breaking inheritance on a subfolder	One folder needs different access from the rest.	Almost always means two sites, not one site with a special folder. See §5 — broken inheritance is where permissions become unauditable.
Sharing “anyone with the link”	It works immediately and needs no thought about who.	Share with named people. Anonymous links outlive their purpose, cannot be traced to a person, and are prohibited above INTERNAL.
Granting access by email thread	The request arrived that way and it seemed rude to redirect it.	Route it to a ticket. The common result of the email route: several grants, no owner approval on record, and no revocation trigger.

4. Granting access

1. The request comes through the service desk, naming the site and the person. Not by reply-all.
2. Tier 2 confirms the site has a named owner and a classification. If it has neither, that is fixed first — a grant on an unowned, unclassified site is a guess.
3. The owner approves, on the ticket. For CONFIDENTIAL and above the approval is explicit, not inferred from silence.
4. Add the person to the appropriate group. Visitors unless they need to edit.
5. For a temporary worker, the access carries an end-date expiry (ACC-09).
6. For an external person, this is M365-14 and needs a sponsor and an expiry before anything is granted.
7. Record the grant, who approved it, and any expiry.

5. Inheritance, and when to break it

By default, everything in a site inherits the site’s permissions. That is what makes a site comprehensible.

Breaking inheritance — giving a library or folder its own permissions — is permitted only with Tier 3 agreement, and only where the alternative genuinely does not work. In practice the alternative almost always works, and it is a second site.

> **Why broken inheritance is treated this seriously**
> A site with unique permissions three folders deep cannot be reviewed, cannot be reasoned about by anybody who did not set it up, and produces exactly the situation where nobody can say who has access to what.
> It is also self-propagating: once one exception exists, the next request gets the same treatment, and within a year the site's permissions are a collection of individual decisions with no model behind them.
> Two sites cost nothing. A site nobody understands costs a great deal at precisely the moment it matters — a departure, an audit, or an incident.

6. OneDrive permissions

- A person's OneDrive belongs to them while they hold the account. IT does not routinely grant others access to it.
- Managers receive delegated access on separation, for 30 days, to retrieve institutional records (ACC-01 §7.2). That is the normal case and it is time-bounded.
- Access to a live employee's OneDrive for any other reason is a Tier 4 decision with a recorded justification. It is an intrusive act and should feel like one.
- Where somebody is routinely sharing from OneDrive, the content belongs in a site (M365-12). Fix the cause rather than the permission.

7. Removing access

- On the leaver procedure, automatically (ACC-01 §7.2 step 3).
- On a role change, as part of the mover delta (ACC-01 §6.2). This is the one that gets skipped.
- At the end of the engagement for temporary workers, without waiting for a request.
- At expiry for guests (M365-14).
- At review, where the owner says the access is no longer needed. Removal never requires the owner's approval when it is triggered by a leaver, an engagement end date or an expiry. Those are automatic, and waiting for an approval is precisely how access persists past its purpose.

8. Review

Classification	Review cadence	Reviewed by
PUBLIC / INTERNAL	Annually	Site owner confirms the Owners and Members groups
CONFIDENTIAL	Annually, and on any departure from the department	Site owner, with Tier 2 supplying the list

Classification	Review cadence	Reviewed by
RESTRICTED	Quarterly	Site owner and Tier 4

Tier 2 supplies the membership list; the owner confirms or corrects it. A non-response is chased once and then escalated to the owner's manager. It is never treated as approval — silence is the commonest way a stale permission becomes permanent.

9. Service levels

Request	Commitment (per GOV-06)
Add somebody to an existing group, owner-approved	P3 — 1 coverage day, usually same day.
Grant on a site with no owner or classification	Held. The site is fixed first; the requester is told why.
External access	M365-14. Not granted until a sponsor and expiry exist.
Break inheritance	P3 at Tier 3. Expect to be offered a second site instead.
Access to a live employee's OneDrive	P3 to Tier 4 as a decision, not a task.
Annual review pack to owners	Issued on schedule by Tier 2.

10. Records

Record	Held in	Retention
Grants, with owner approval and any expiry	Ticket	3 years
Broken-inheritance decisions and their justification	Site register + Tier 3 record	Life of the site
OneDrive access decisions for live employees	Tier 4 record	3 years
Review confirmations	Ticket	3 years

11. Related documents

ID	Title	Relationship
M365-15	Data Classification & Handling	Supplies the classification every rule here depends on.
M365-10	SharePoint Site Request, Provisioning & Ownership	Creates the site, owner and groups this document then manages.
M365-12	OneDrive Appropriate Use	§6 — fix the cause, not the permission.
M365-13	Legacy File Share Retirement	The largest single application of this document.
M365-14	External Sharing & Guest Access Governance	Anything involving a person from outside the organization.
M365-03	Shared Mailbox Request & Ownership	The same model for mailboxes.

ID	Title	Relationship
ACC-01	Account Lifecycle	§6.2 mover delta and §7.2 leaver removal.
ACC-02	Account Naming Standard	ROLE- group naming.
ACC-17	Periodic Access Review	Consumes §8.
GOV-06	Service Commitments	Supplies §9.

Appendix A — Request card

	Check	If not
1	Did this arrive as a ticket rather than an email thread?	Move it to a ticket. Politely, and explain why once.
2	Does the site have a named owner?	Fix that first (M365-10). A grant on an unowned site is a guess.
3	Is the site classified?	Fix that first (M365-15). Otherwise you cannot know what the rules are.
4	Has the owner approved, on the ticket?	Wait. For CONFIDENTIAL and above, silence is not approval.
5	Is there a group that fits?	If not, the site needs a group — not an individual grant.
6	Do they need to edit, or only to read?	Visitors by default. Read access is cheap.
7	Temporary worker?	End-of-engagement expiry (ACC-09).
8	External person?	Stop. M365-14 — sponsor and expiry first.

Appendix B — Owner’s annual review

Sent to you by IT with the current membership attached. Five minutes.

1	Read the list. Is everybody on it still doing work that needs this site?
2	Anybody who has changed role, even inside your department? They may not need it any more.
3	Anybody who has left? They should already be gone — if they are not, tell IT, because that is a process failure worth knowing about.
4	Anybody on Members who only ever reads? Move them to Visitors.
5	Reply confirming or correcting. If we do not hear from you we will chase once, then ask your manager — we will not treat silence as a yes.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.